



Gestão de segredos e **rotação de credenciais**

Autor: PDI Marcos Luciano - marcosluciano.rodrigues@v4company.com

Unidade: FV Marketing / V4 Company: Automação & Infraestrutura

Módulo: 06 | Governança de IA e Segurança

Data: Setembro 2026

Status: **NÃO PUBLICADO** · Desenvolvido / Homologação pendente

Versão: 1.0

pdi-governanca-ia-seguranca-a3

1. Contexto

Tokens de Meta Ads, Google, CRM, banco e webhooks circulam entre workers, CIs e máquinas do time sem inventário, sem dono e sem prazo de troca. Chave sem dono e chave eterna.

Esta atividade fecha a causa: **cofre central, entrega por referência, rotação com prazo e varredura que falha o build.**

2. Diagnóstico

Segredo em chat, planilha ou commit de acesso a verba de mídia e base de leads; a troca emergencial vira madrugada porque ninguém sabe onde cada chave está usada. O custo do vazamento é proporcional ao tempo de exposição, e hoje esse tempo é indefinido.

SINTOMA	RISCO	CORREÇÃO
---------	-------	----------

.env no chat ou wiki	Exposição permanente	Cofre + referência
Chave estática no CI	Abuso silencioso	OIDC ou rotação curta
Sem rotação	Janela infinita	30/90/180 dias com dono

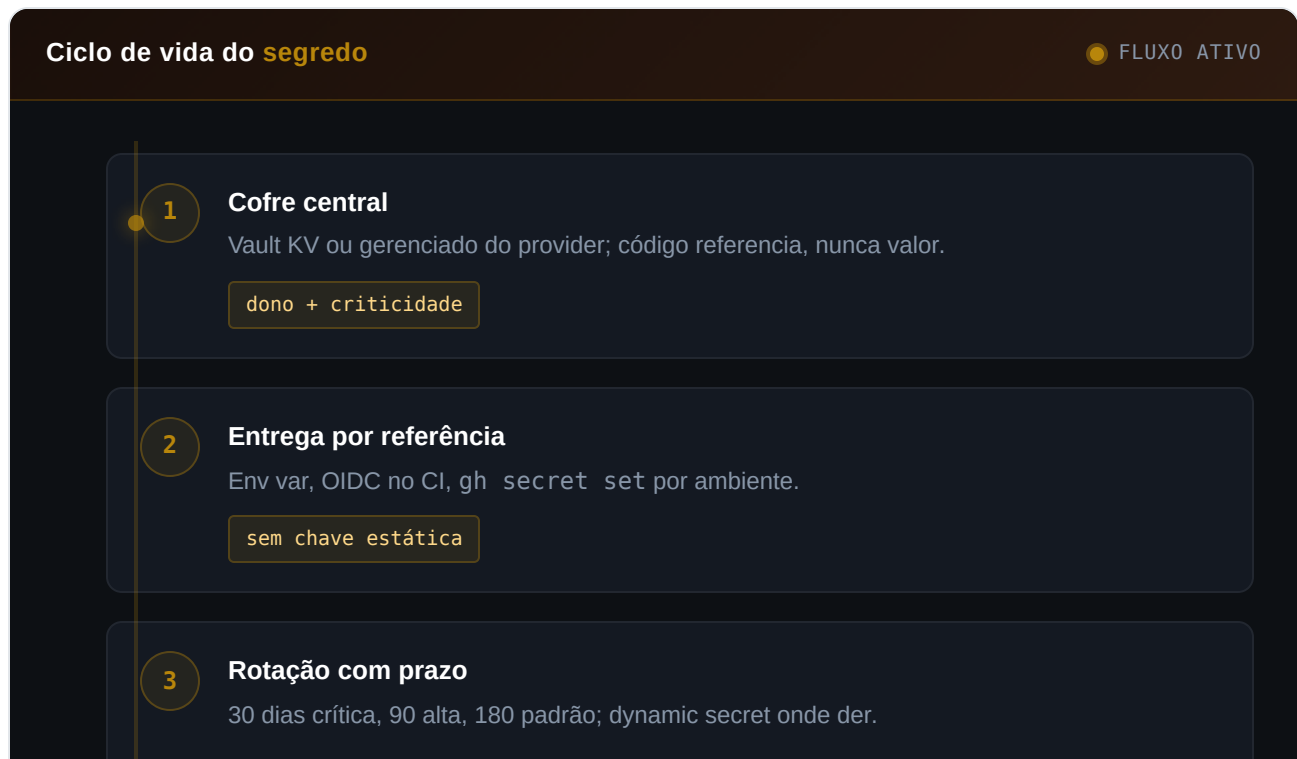
3. Solução

Standard com princípios, tabela de guarda e entrega, prazos e resposta a vazamento em 5 passos. Código `secrets_audit.py` executável: 5 famílias de padrões reais, checagem de `.gitignore` e exit code para o CI. Comandos do GitHub Docs verificados na entrega.

```
gh secret set NOME_DO_SECRET
gh secret set NOME_DO_SECRET < secret.txt
gh secret set --env PROD NOME_DO_SECRET
gh secret list
```

- Produção no cofre, CI em secrets por ambiente, local em `.env`` fora do git
- Dynamic secrets com TTL onde o provider suporta

4. Como funciona



gerar, validar, revogar

4

secrets_audit.py

varre

5 padrões reais + .gitignore; achado falha o build.

exit 1 = CI vermelho

5

Vazou, gira

Revogar, girar, auditar uso, comunicar, post-mortem. Crítica em 4 h.

procedimento ensaiado

secrets_audit.py | self-test: AKIA + ghp detectados

comandos do GitHub Docs

5. Entregas

ARQUIVO	CONTEÚDO
1-standards/STANDARD-SEGREDOS-ROTACAO.md	Princípios, guarda e entrega, rotação, resposta
2-implementacao/secrets_audit.py	Varredura executável com self-test passando
2-implementacao/CHECKLIST-SEGREDOS.md	Higiene mensal, 8 itens
7-apresentacao/	Deck de 12 slides, demo, roteiro com 5 Q and A, este relatório em HTML, DOCX e PDF

6. Métricas de sucesso

MÉTRICA	ATUAL	META
Críticas com rotação	0% (baseline desta PDI)	100% em 90 dias (meta)
Segredos em repos	a medir na primeira rodada	0 após remediação (meta)

Giro de chave vazada	sem rotina	até 4 h (meta)
Status: Desenvolvido em Setembro 2026, homologação pendente: migrar Ads e CRM para o cofre e ligar a varredura no CI.		